

# ACTIVITÉ – Bonnes pratiques de protection des applications Web

## Objectifs pédagogiques

À la fin de cette activité, le stagiaire doit être capable de :

- Identifier les principales bonnes pratiques de sécurité Web.
- Associer une attaque à des mesures de prévention adaptées.
- Comprendre qu'une seule protection n'est pas suffisante.
- Choisir des protections adaptées à un scénario.
- Comprendre le principe de défense en profondeur.

---

## PARTIE 1 — Identifier les bonnes pratiques

### Question 1

Compléter le tableau en expliquant simplement l'utilité de chaque bonne pratique.

| Bonne pratique                            | À quoi sert-elle ? | Exemple |
|-------------------------------------------|--------------------|---------|
| Validation des entrées                    |                    |         |
| Échappement / encodage des sorties        |                    |         |
| Requêtes SQL préparées                    |                    |         |
| Contrôle des droits d'accès               |                    |         |
| Authentification forte                    |                    |         |
| MFA                                       |                    |         |
| CAPTCHA                                   |                    |         |
| Limitation des tentatives (Rate limiting) |                    |         |
| Gestion sécurisée des sessions            |                    |         |
| HTTPS                                     |                    |         |
| Mise à jour des composants                |                    |         |
| Gestion sécurisée des fichiers uploadés   |                    |         |
| Journalisation / Logs                     |                    |         |
| Sauvegardes                               |                    |         |

## PARTIE 2 — Classer les protections

### Question 2

Classer les mesures suivantes dans la famille de sécurité qui correspond principalement à leur rôle.

#### Familles

**A. Sécuriser les entrées et le code**

**B. Sécuriser l'authentification et les accès**

**C. Sécuriser les données et les communications**

**D. Sécuriser le serveur et l'environnement**

**E. Surveiller et détecter**

**F. Assurer la continuité et la récupération**

#### Mesures à classer

- Validation des entrées
- Requêtes SQL préparées
- Encodage des sorties
- MFA
- CAPTCHA
- Rate limiting
- Contrôle des autorisations
- Gestion sécurisée des sessions
- HTTPS
- Chiffrement des données
- Sauvegardes
- Mise à jour des composants
- Pare-feu
- WAF
- Journalisation
- Alertes de sécurité

## PARTIE 3 — Une attaque, quelles protections ?

### Question 3

Pour chaque attaque ou vulnérabilité, proposer **au moins deux mesures de protection adaptées**.

| Attaque / Vulnérabilité          | Protection 1 | Protection 2 |
|----------------------------------|--------------|--------------|
| Injection SQL                    |              |              |
| XSS                              |              |              |
| Broken Access Control / IDOR     |              |              |
| Brute Force                      |              |              |
| Vol d'identifiants               |              |              |
| Session Hijacking                |              |              |
| CSRF                             |              |              |
| Upload de fichiers malveillants  |              |              |
| Composant vulnérable ou obsolète |              |              |
| Mauvaise configuration           |              |              |

## PARTIE 4 — Cas particulier : protéger l'authentification

### Question 4

Un site Web possède uniquement un formulaire :

**Utilisateur + Mot de passe**

Il n'existe aucune limitation du nombre de tentatives de connexion.

### Travail demandé

1. Quelle attaque peut être réalisée automatiquement contre ce formulaire ?

2. Expliquer le rôle de chacune des protections suivantes :

- Mot de passe robuste
- MFA
- Rate limiting
- CAPTCHA
- Verrouillage ou délai progressif
- Journalisation des échecs de connexion

3. Le CAPTCHA seul suffit-il pour sécuriser l'authentification ? Justifier.

4. Proposer une combinaison d'au moins **3 protections**.

## PARTIE 5 — Protection à plusieurs niveaux

### Question 5

Une application Web peut être protégée à plusieurs niveaux.

Compléter le schéma suivant en donnant au moins **deux protections par niveau**.

#### UTILISATEUR / AUTHENTIFICATION



Protection 1 : \_\_\_\_\_

Protection 2 : \_\_\_\_\_

#### APPLICATION WEB



Protection 1 : \_\_\_\_\_

Protection 2 : \_\_\_\_\_

#### SERVEUR / RÉSEAU



Protection 1 : \_\_\_\_\_

Protection 2 : \_\_\_\_\_

#### DONNÉES



Protection 1 : \_\_\_\_\_

Protection 2 : \_\_\_\_\_

#### SURVEILLANCE



Protection 1 : \_\_\_\_\_

Protection 2 : \_\_\_\_\_

## PARTIE 6 — Mise en situation

### Scénario

Une entreprise vient de déployer une nouvelle application Web permettant aux employés de consulter et télécharger leurs documents.

Lors d'une vérification, vous constatez :

- Le site accepte encore HTTP ;
- L'authentification repose uniquement sur un mot de passe ;
- Le nombre de tentatives de connexion est illimité ;
- Aucun CAPTCHA n'est utilisé lors d'activités suspectes ;
- Certaines entrées utilisateur ne sont pas correctement contrôlées ;
- Un utilisateur peut modifier l'identifiant d'un document dans l'url ;
- L'application accepte l'upload de fichiers sans contrôle suffisant ;
- Plusieurs composants ne sont pas à jour ;
- Les erreurs détaillées de l'application sont affichées aux utilisateurs ;
- Les tentatives de connexion ne sont pas journalisées ;
- Aucune sauvegarde récente n'est disponible.

### Question 6

Identifier **8 problèmes de sécurité** et proposer une protection pour chacun.

| Problème | Risque / attaque possible | Protection proposée |
|----------|---------------------------|---------------------|
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |
|          |                           |                     |

## PARTIE 7 — Une seule protection suffit-elle ?

### Question 7

L'administrateur propose :

« Nous allons installer un pare-feu et un WAF. L'application sera alors sécurisée. »

1. Expliquer pourquoi cette solution n'est pas suffisante.
2. Donner **3 vulnérabilités du scénario** qui nécessitent également une correction au niveau de l'application ou de sa configuration.
3. Donner un exemple où plusieurs protections peuvent être combinées contre une même attaque.

## PARTIE 8 — Construire une défense en profondeur

### Question 8

À partir du scénario précédent, proposer une architecture de protection simple.

**Internet**



**Pare-feu / WAF**



**Serveur Web sécurisé et à jour**



**Application sécurisée**



**Authentification et contrôle des accès**



**Données protégées**



**Logs et surveillance**



**Sauvegardes**

Pour chaque niveau, donner **au moins une mesure de sécurité**.

## PARTIE 9 — Checklist finale

### Question 9

Vous devez vérifier une application avant sa mise en production.

Construire une **checklist de 10 bonnes pratiques de sécurité**.

Exemple de présentation :

- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_
- ☐ \_\_\_\_\_

## PARTIE 10 — Synthèse

### Question 10

Expliquer en **5 lignes maximum** pourquoi :

**« Sécuriser une application Web ne consiste pas à installer une seule solution de sécurité. »**

Utiliser dans la réponse la notion de :

**Défense en profondeur**